

Kerberos Dust — Threat Hunting & DFIR Investigation Report

Executive Summary & Incident Overview

- **Incident ID:** INC-2026-0881
- **Target Organization:** Synapse Financial Technologies Ltd (synapse.corp)
- **Classification:** High / Critical (Active Directory Domain Compromise)
- **Domain Controller:** DC01.synapse.corp (10.10.10.5)
- **Compromised Endpoint:** WS01.synapse.corp (10.10.10.50)
- **Incident Scope:** Active Directory Kerberos Authentication & Lateral Movement
- **Incident Timeline:** August 28, 2026 (14:10:00 – 14:40:00 UTC)

On August 28, 2026, at approximately 14:10 UTC, the Security Operations Center (SOC) detected abnormal Kerberos ticket requests and domain replication operations originating from internal subnet 10.10.10.0/24 . A complete forensic package comprising Domain Controller event logs (Security_Events.json), endpoint Sysmon telemetry (Sysmon_Events.json), an incident timeline (Incident_Timeline.csv), and full packet capture (kerberos_traffic.pcap) was captured for comprehensive forensic triage.

Evidence Inventory & SHA-256 Checksums

Artifact File	Description	Evidence Source
kerberos_traffic.pcap	Full packet capture of Kerberos/LDAP/MSRPC traffic	Network TAP (10.10.10.0/24)
Security_Events.json	Windows Security Event Log (Security.evtx export)	DC01.synapse.corp
Sysmon_Events.json	Microsoft-Windows-Sysmon Process/Network Telemetry	WS01.synapse.corp
Incident_Timeline.csv	Cross-correlated forensic timeline (UTC)	SIEM Correlation Engine

Attack Chain Overview

[Attacker / Compromised Host: WS01 (10.10.10.50)]

- 1. AS-REP Roasting (14:10:05 UTC)
 - TGT requested without Pre-Authentication (Event ID 4768)
 - Targeted Account: 'backup_admin' (RC4-HMAC etype 0x17)
- 2. Targeted Kerberoasting (14:15:22 UTC)
 - SPN Request for 'MSSQLSvc/db01.synapse.corp:1433' (Event ID 4769)
 - Target Service Account: 'svc_sql' (RC4 downgrade etype 0x17)
- 3. Overpass-the-Hash / Pass-the-Ticket (14:22:40 UTC)
 - Logon Type 9 (NewCredentials) initiated via Rubeus.exe
 - Upgraded Kerberos TGT injected into memory session
- 4. DCSync Domain Replication Abuse (14:30:15 UTC)
 - MSRPC / DRSUAPI call: DS-Replication-Get-Changes-All (Event ID 4662)
 - Complete hash dump of 'SYNAPSE\krbtgt' and 'SYNAPSE\Administrator'
- 5. Persistence Establishment (14:38:50 UTC)
 - Scheduled Task '\SynapseHealthCheck' registered on DC01 (Event ID 4698)
 - Encoded PowerShell payload executed under SYSTEM authority

Step-by-Step Forensic Investigation (Q&A Framework)

Question 1: Initial Compromise Source

What is the IP address and hostname of the initial compromised workstation used to launch the Active Directory attack chain?

- **Answer:** 10.10.10.50 / WS01.synapse.corp
- **Investigation Query (Wireshark / Splunk):**

Wireshark: ip.dst == 10.10.10.5 && (kerberos || ldap)

Splunk: index=winsec EventCode IN (4768, 4769) | stats count by IPAddress

- **Forensic Evidence:**
Inspecting the incoming Kerberos AS-REQ and LDAP requests against DC01

(10.10.10.5) demonstrates that all initial malicious queries originated from client IP 10.10.10.50 . Sysmon logs confirm the endpoint hostname as WS01.synapse.corp .

Question 2: AS-REP Roasting Target

Which Active Directory user account was targeted for AS-REP Roasting due to having Kerberos Pre-Authentication disabled (DONT_REQ_PREAUTH)?

- **Answer:** backup_admin
- **Investigation Query:**

```
Splunk: index=winsec EventCode=4768 PreAuthType=0  
TicketEncryptionType=0x17  
Wireshark: kerberos.msg_type == 10 && kerberos.padata_type == 0
```

- **Forensic Evidence:**
At 2026-08-28 14:10:05 UTC , DC01 recorded Event ID 4768 for account backup_admin with PreAuthType: 0 (No Pre-Authentication). The DC returned an AS-REP response containing the encrypted ticket that could be cracked offline.
-

Question 3: Kerberos Encryption Downgrade

What Kerberos ticket encryption type (in hexadecimal notation) was requested by the attacker in both the AS-REP and TGS requests to facilitate offline brute-forcing?

- **Answer:** 0x17 (RC4-HMAC)
- **Investigation Query:**

```
Wireshark: kerberos.etype == 23  
Splunk: index=winsec EventCode IN (4768, 4769) | table _time,  
TargetUserName, TicketEncryptionType
```

- **Forensic Evidence:**
Modern Active Directory environments enforce AES256 (0x12). The attacker explicitly requested 0x17 (RC4-HMAC / 23) in both requests to extract faster, MD4-based HMAC hashes for cracking via Hashcat mode 18200 and 13100 .
-

Question 4: Targeted Kerberoasting SPN

What Service Principal Name (SPN) was requested during the targeted Kerberoasting attack?

- **Answer:** MSSQLSvc/db01.synapse.corp:1433
- **Investigation Query:**

```
Wireshark: kerberos.sname.string == "MSSQLSvc"  
Splunk: index=winsec EventCode=4769 ServiceName="*MSSQLSvc"
```

- **Forensic Evidence:**
At 14:15:22 UTC , Event ID 4769 was generated on DC01 with ServiceName: MSSQLSvc/db01.synapse.corp:1433 requested from workstation 10.10.10.50 .
-

Question 5: Service Account Compromise

What is the underlying domain username associated with the Kerberoasted service instance?

- **Answer:** svc_sql
- **Investigation Query:**

```
PowerShell / LDAP: Get-ADUser -Filter {ServicePrincipalName -like  
"*MSSQLSvc*"} -Properties ServicePrincipalName
```

- **Forensic Evidence:**
Cross-referencing the Active Directory LDAP schema and Sysmon process commands confirms that MSSQLSvc/db01.synapse.corp:1433 maps directly to the service account SYNAPSE\svc_sql .
-

Question 6: Offensive Tooling on Endpoint

What offensive tool executable and full path on WS01 was executed by the threat actor to perform AS-REP roasting and Kerberoasting?

- **Answer:** C:\Users\j.doe\AppData\Local\Temp\Rubeus.exe
- **Investigation Query (Sysmon):**

```
Splunk: index=sysmon EventCode=1 Image="*Rubeus.exe*"  
KQL: SysmonEvent | where EventID == 1 and CommandLine contains  
"asreproast"
```

- **Forensic Evidence:**

Sysmon Event ID 1 on WS01 recorded the execution of Rubeus.exe located at C:\Users\j.doe\AppData\Local\Temp\Rubeus.exe with command-line arguments:

```
Rubeus.exe asreproast /user:backup_admin /domain:synapse.corp /format:hashcat
```

```
Rubeus.exe kerberoast /spn:MSSQLSvc/db01.synapse.corp:1433 /format:hashcat
```

Question 7: Overpass-the-Hash Logon Type

What Windows Logon Type was recorded when the threat actor utilized the cracked credentials to spawn a new privileged token on WS01 ?

- **Answer:** LogonType 9 (NewCredentials)
- **Investigation Query:**

```
Splunk: index=winsec EventCode=4624 LogonType=9
```

- **Forensic Evidence:**

At 14:22:40 UTC , Windows Security Event ID 4624 was logged on WS01 with LogonType: 9 (NewCredentials), spawned by calling process Rubeus.exe . This logon type indicates memory injection of alternative NTLM/Kerberos credentials.

Question 8: DCSync Extended Access Right GUID

What is the Active Directory Extended Access Right GUID invoked by the attacker to perform the DCSync domain replication attack?

- **Answer:** 1131f6aa-9c07-11d1-f79f-00c04fc2dcd2 (DS-Replication-Get-Changes-All)
- **Investigation Query:**

```
Splunk: index=winsec EventCode=4662 ObjectType="{19195a5b-6da0-11d0-afd3-00c04fd930c9}" Properties="*{1131f6aa-9c07-11d1-f79f-00c04fc2dcd2}*"
```

- **Forensic Evidence:**

Event ID 4662 was triggered on DC01 by subject SYNAPSE\backup_admin attempting domain object replication (AccessMask: 0x100) against property {1131f6aa-9c07-11d1-f79f-00c04fc2dcd2} .

Question 9: High-Privilege Account Replication

Which two critical domain accounts were targeted for credential extraction via the DCSync attack?

- **Answer:** SYNAPSE\krbtgt and SYNAPSE\Administrator
- **Investigation Query:**

```
Sysmon: EventCode=1 CommandLine="*lsadump::dcsync*
```

- **Forensic Evidence:**
Sysmon Event ID 1 on WS01 at 14:30:13 UTC shows mimikatz.exe executing:
mimikatz.exe "lsadump::dcsync /domain:synapse.corp /user:krbtgt"
"lsadump::dcsync /domain:synapse.corp /user:Administrator" exit

Question 10: Persistence Mechanism

What is the name of the malicious scheduled task registered on DC01 , and what system LOLBAS utility was configured to execute?

- **Answer:** \SynapseHealthCheck / powershell.exe
- **Investigation Query:**

```
Splunk: index=winsec EventCode=4698 TaskName="*Synapse*
```

- **Forensic Evidence:**
At 14:38:50 UTC , Event ID 4698 was logged on DC01 recording the creation of task \SynapseHealthCheck configured to run powershell.exe with hidden window execution parameters.

Detection Engineering & Sigma Rules

Sigma Rule 1: AS-REP Roasting Ticket Request

```
title: AS-REP Roasting Ticket Request Without Pre-Authentication
id: a874f63c-912b-4e12-8921-293849102834
status: production
description: Detects Kerberos TGT requests with Pre-Authentication disabled
and RC4 encryption downgrade.
author: Synapse Incident Response Team
logsource:
```

```
product: windows
service: security
detection:
  selection:
    EventID: 4768
    PreAuthType: 0
    TicketEncryptionType: '0x17'
    Status: '0x0'
  condition: selection
falsepositives:
  - Legacy service accounts specifically configured without pre-auth
    (should be remediated)
level: high
```

Sigma Rule 2: Non-DC Account Performing Directory Replication (DCSync)

```
title: Active Directory Replication by Non-Domain Controller (DCSync)
id: c7128941-1029-4829-ba91-192837461928
status: production
description: Detects invocation of DS-Replication-Get-Changes-All extended
access right by standard user accounts.
logsource:
  product: windows
  service: security
detection:
  selection:
    EventID: 4662
    AccessMask: '0x100'
    Properties|contains: '{1131f6aa-9c07-11d1-f79f-00c04fc2dcd2}'
  filter_dc:
    SubjectUserName|endswith: '$'
  condition: selection and not filter_dc
falsepositives:
  - Legitimate domain controller synchronization
  - Azure AD Connect synchronization account (MSOL_*)
level: critical
```

Remediation & Hardening Roadmap

1. Enforce Kerberos Pre-Authentication:

Audit all Active Directory user objects with `Get-ADUser -Filter {DoesNotRequirePreAuth`

`-eq $True}` and ensure `DONT_REQ_PREAUTH` (flag `0x400000`) is disabled across all domain accounts.

2. **Disable Weak Kerberos Encryption Types (RC4):**

Configure Domain Group Policy: *Computer Configuration → Windows Settings → Security Settings → Local Policies → Security Options → Network security: Configure encryption types allowed for Kerberos* to enforce **AES128_HMAC_SHA1** and **AES256_HMAC_SHA1** while disabling RC4.

3. **Restrict Directory Replication Permissions (DCSync Mitigation):**

Audit the root domain ACLs and ensure `Replicating Directory Changes` and `Replicating Directory Changes All` permissions are exclusively assigned to authorized Domain Controllers and designated Tier-0 sync identities.

4. **Service Account Hardening (Managed Service Accounts):**

Migrate standalone service accounts with SPNs to **Group Managed Service Accounts (gMSA)** with 128-character automatically rotated passwords to eliminate Kerberoasting attack surface.